Audit de securite - Plateforme Code un max

Identification d'un malware simulé et ses indicateurs de compromissions depuis le poste attaquant

---

1. Vérifier que les conteneurs du lab sont actifs

```
docker ps --format "{{.Names}} {{.Image}}"
```

```
brandon@debian:~/cybersec-audit-codemax$ docker ps --format "{{.Names}} {{.Image}}"
attaquant debian:12
dvwa-cible vulnerables/web-dvwa
brandon@debian:~/cybersec-audit-codemax$
```

2. Création d'un faut échantillon de malware inoffensif

```
docker exec attaquant bash -c "printf 'MALWARE-SAMPLE-
EDU\nbeacon=http://10.40.0.10/c2/checkin\npersist=cron\n' > /data/sample-
malware.txt"
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant cat /data/sample-malware.txt
MALWARE-SAMPLE-
EDU
beacon=http://10.40.0.10/c2/checkin
persist=cron
brandon@debian:~/cybersec-audit-codemax$
```

3. Calculer l'empreinte SHA-256 de l'échantillon

```
docker exec attaquant sha256sum /data/sample-malware.txt
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant sha256sum /data/sample-malware.txt
c5022ae567c60e6ef1e20df004bd697d472667b58bd5b9a62a5f046ac73beb9f  /data/sample-malware.txt
brandon@debian:~/cybersec-audit-codemax$
```

4. Extraire les chaînes suspectes de l'échantillon

```
docker exec attaquant grep -E "beacon|persist|c2" /data/sample-malware.txt
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant grep -E "beacon|persist|c2" /data/sample-malware.txt
beacon=http://10.40.0.10/c2/checkin
persist=cron
brandon@debian:~/cybersec-audit-codemax$
```

5. Démarrer la capture réseau sur l'hôte attaquant

5.1 Lancer la capture dans `/tmp`

```
docker exec attaquant bash -c "tshark -i eth0 -a duration:15 -w
/tmp/capture-c2.pcap > /dev/null 2>&1 &"
```

5.2 Générer la requête pendant la capture

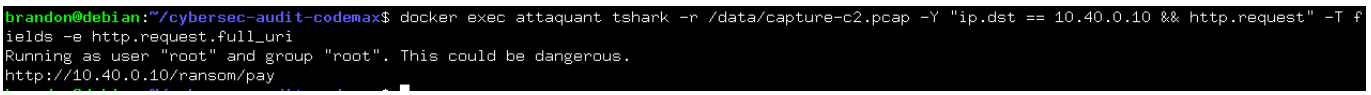
```
docker exec attaquant curl -s -o /dev/null -w "%{http_code}\n"
http://10.40.0.10/c2/checkin
```

5.3 Attendre les 15 secondes, puis copier le fichier vers `/data`

```
sleep 15
docker exec attaquant cp /tmp/capture-c2.pcap /data/
```

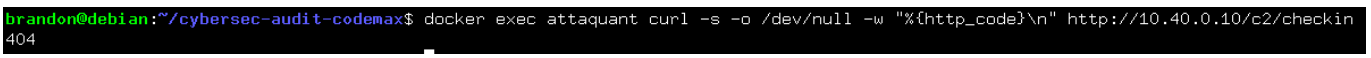
5.4 Relire la capture

```
docker exec attaquant tshark -r /data/capture-c2.pcap -Y "ip.dst ==
10.40.0.10 && http.request" -T fields -e http.request.full_uri
```



6. Simuler la prise de contact vers le faux serveur C2

```
docker exec attaquant curl -s -o /dev/null -w "%{http_code}\n"
http://10.40.0.10/c2/checkin
```



7. Analyser le trafic capturé vers la cible

```
docker exec attaquant tshark -r /data/capture-c2.pcap -Y "ip.dst ==
10.40.0.10 && http.request" -T fields -e http.request.full_uri
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant tshark -r /data/capture-c2.pcap -Y "ip.dst == 10.40.0.10 && http.request" -T fields -e http.request.full_uri
Running as user "root" and group "root". This could be dangerous.
http://10.40.0.10/c2/checkin
brandon@debian:~/cybersec-audit-codemax$
```

8. Présentation des IoC

Indicateurs de compromission (IoC)

- Signature : `c5022ae567c60e6ef1e20df004bd697d472667b58bd5b9a62a5f046ac73beb9f` /data/sample-malware.txt
- Persistance : cron
  - Permet d'exécuter à intervalles régulier des scripts, backdoors ou reverse shell ou au démarrage d'un poste infecté.
- URL de contact C2 : http://10.40.0.10/c2/checkin

Recommandations

Prévention

- Mettre en place des sauvegardes hors ligne (règle 3-2-1-1-0).
  - 3 copies des données
  - 2 supports de stockages différents
  - 1 copie hors site
  - 1 copie immuable ou hors ligne
  - 0 erreur lors des restauration
- Filtrer rigoureusement les pièces jointes et sensibiliser les utilisateurs.

Réponse à incident

- Isoler immédiatement l'hôte compromis du réseau sans éteindre le poste. Permet l'analyse forensic et analyser notamment les traces dans la RAM.
- Identifier et bloquer l'indicateur de compromission (URL/IP de contact potentiel vers un serveur C2).

Tableau comparatif des types de malwares (Bonus)

Type de malware	Vecteur de compromission typique	Indicateur de compromission (IoC) représentatif
Virus	Fichiers exécutables partagés, supports amovibles	Modification anormale de l'empreinte de binaires locaux
Ver	Vulnérabilité réseau non corrigée (propagation autonome)	Trafic de balayage massif de ports (*scanning*)
Cheval de Troie	Logiciel piraté ou téléchargé depuis une source non sûre	Connexion sortante vers un port inhabituel (ex: C2 externe)
Ransomware	Campagne de phishing, pièce jointe malveillante, RDP exposé	Fichiers renommés en masse avec une extension spécifique, note de rançon

Type de malware	Vecteur de compromission typique	Indicateur de compromission (IoC) représentatif
Botnet	Exploitation d'application web ou identifiants faibles	Connexions périodiques régulières (*beaconing*) vers un serveur de commande

Fichier de test EICAR (Indicateur universel)

- **Nom du fichier** : `/data/eicar.txt`
- **Type** : Fichier de test standard anti-malware (inoffensif)
- **Empreinte SHA-256** : `caa46ea29a2181723bebde73d2e627e5079a49eefeede2465c7292da903dbdf0`
- **Comportement** : Innofensif, le fichier EICAR est conçu pour déclencher systématiquement les signatures des solutions de sécurité à des fins de validation de chaîne de détection.
- **Extraction de chaînes caractéristique EICAR** :

```
docker exec attaquant grep -E "EICAR" /data/eicar.txt
```

```
brandon@debian:~/cybersec-audit-codemax$ docker exec attaquant grep -E "EICAR" /data/eicar.txt
X5O\!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*
brandon@debian:~/cybersec-audit-codemax$
```